Relatório de teste: segurança (pentest)

SafeID · Commit a778b8b da main · Executado em 03/11/2026 · Horários em UTC

> **Resultado: há achado alto em aberto.** As varreduras e os testes dirigidos não encontraram falha explorável na aplicação, mas a auditoria de dependências aponta 6 pacotes de severidade alta no back-end, e um deles (body-parser) é alcançável. Portanto, o critério da Seção 6.3 do documento ("nenhum achado de severidade alta ou crítica em aberto") **ainda não está cumprido**.

Escopo e autorização

- Autorizado pela equipe, dona do sistema, apenas sobre os domínios e a infraestrutura do próprio projeto.
- **Em produção:** só testes de baixo impacto: varredura passiva e verificações dirigidas com poucas requisições.
- **Em cópia local descartável:** varredura ativa, com PostgreSQL e Redis próprios, HIBP simulada, e-mail só em log.
- **Fora do escopo:** negação de serviço, engenharia social e testes na infraestrutura da AWS.

Ferramentas

- OWASP ZAP 2.17.0: `zap-baseline`, `zap-api-scan` e `zap-full-scan`.
- Scripts versionados: `tests/security/verificacoes.py` e `tests/security/autorizacao_local.py`.
- `npm audit --omit=dev` no back-end e no front-end.

Verificações dirigidas em produção: 50 de 50 aprovadas

Categoria	Verificações	Aprovadas
Transporte	6	6
Cabeçalhos	12	12
CORS	1	1
Autenticação	12	12
Entrada	7	7
Exposição	9	9
Enumeração	1	1
Limite de tentativas	2	2

Cobrem TLS e redirecionamento HTTPS, cabeçalhos, CORS, rotas sem login, JWT forjado (alg none e assinatura falsa), injeção SQL e NoSQL no login, campos extras, exposição de arquivos, enumeração de contas e bloqueio após tentativas de login.

Autorização entre usuários, em cópia local: 11 de 11 aprovadas

Verificação	Resultado
o dono lê a própria análise	**Aprovada**
outro usuário não lê a análise pelo jobId	**Aprovada**
o histórico de outro usuário não aparece	**Aprovada**
outro usuário não marca a notificação alheia	**Aprovada**
a notificação alheia segue não lida	**Aprovada**
o dono marca a própria notificação	**Aprovada**
o refresh token não vale como acesso	**Aprovada**
o token de acesso não vale como refresh	**Aprovada**
a exportação traz só a própria conta	**Aprovada**
a exclusão só apaga a conta do token	**Aprovada**
token de conta apagada deixa de valer	**Aprovada**

Varreduras do ZAP (número de tipos de alerta)

Alvo	Modo	Alto	Médio	Baixo	Informativo
www.safeid.app.br (produção)	Passivo	0	1	4	4
api.safeid.app.br (produção)	Passivo	0	0	0	2
API local, autenticada, 38 URLs	Ativo	0	0	2	3
Front local	Ativo	0	1	0	1

Achados

ID	Severidade	Achado	Situação e recomendação
S01	Alta	npm audit: 6 pacotes altos e 7 moderados nas dependências de produção do back-end. Front-end: nenhum.	**Em aberto.** Atualizar follow-redirects e qs com `npm audit fix`; forçar body-parser corrigido ou migrar para o NestJS 11 ou superior e testar.
S02	Média	CSP do site com style-src 'unsafe-inline'.	Aceito: exigido por React e Tailwind. script-src é só 'self', o que limita o impacto.
S03	Baixa	Cabeçalhos COOP, COEP e CORP ausentes no site.	Recomendado incluir COOP e CORP na política do CloudFront. COEP não é necessário.
S04	Baixa	GET /scan/:jobId de outro usuário responde 200 com corpo vazio.	Sem vazamento: a consulta filtra por userId. Recomendado responder 404.
S05	Baixa	Cabeçalho 'Server: AmazonS3' no site.	Aceito: não expõe versão.
S06	Baixa	Redis sem TLS nem criptografia em repouso.	Já conhecido, na rede privada. Dados do cache usam HMAC. Avaliar ao sair do plano atual.

ID	Severidade	Achado	Situação e recomendação
—	Descartados	'HTTP Only Site' (efeito do ambiente local) e 'Timestamp Disclosure' (datas legítimas no JSON).	Falsos positivos, sem ação.

Dependências altas: alcance no código

Pacote	Alertas altos	Alcançável	Análise
body-parser	1	Sim	Rotas JSON públicas passam por ele; negação de serviço com corpo comprimido.
follow-redirects	3	Limitado	Usado pelo axios no cliente da HIBP. Só importaria se a HIBP redirecionasse para outra origem, levando o cabeçalho da chave.
js-yaml	3	Não	Vem do @nestjs/swagger, desligado em produção, sem entrada externa.
lodash	1	Não	Vem do @nestjs/swagger; a aplicação não importa lodash.
multer	7	Não	O código não tem rota de upload nem FileInterceptor.

O alcance é uma análise da leitura do código, sem prova de conceito. Os alertas completos estão em `docs/testes/dados/npm-audit-server.json`.

Incidente durante o teste

> Na varredura ativa local, o ZAP seguiu o redirecionamento de `/api/v1/auth/google` e enviou dezenas de requisições a `accounts.google.com`, **fora do escopo autorizado**. O client_id era um valor de exemplo, sem credenciais. Os resultados desse domínio foram descartados dos dados publicados. Em execuções futuras, essa rota deve ser excluída da varredura.

Limitações

- **Não substitui um pentest manual por terceiros:** o teste é automatizado, com verificações dirigidas pela própria equipe, e não prova ausência de falhas.
- Os limites por rota (login 5 por minuto, cadastro 5 a cada 15 minutos) continuaram ativos na cópia local, o que reduz a cobertura do ZAP nessas rotas.
- Os fluxos com HIBP real, IA e login com Google não passaram pela varredura ativa.
- Uma primeira varredura da API alcançou só 3 URLs por erro de configuração. Ela foi descartada e repetida com 38 URLs; só a segunda consta aqui.

Como repetir

Ver `docs/testes/README.md`. Dados brutos em `docs/testes/dados/`.